

# Security of Smart Environments - Notes

## IMPORTANT WARNING

- These notes have been made starting from my notes taken during lessons and the power points published by the professor, then rearranged through the help of Gemini to produce a narrative flow.
- All the content belongs to the Professor of the course.
- While I try to ensure everything is inside these notes, please don't use them as a "source of truth", and study from official sources as well.

## CHAPTER 1: IoT

### 1.1 The Concept of Smart Environments

A smart environment is fundamentally a physical space—such as a home, building, city, factory, hospital, or vehicle—and not merely a digital domain. It serves as a bridge that connects the physical and digital worlds through the strategic use of digital devices. This instrumented space continuously perceives what is happening inside it, reasons and learns based on the collected data, and subsequently acts back upon the physical world. As described by Cook and Das in 2004, it can be envisioned as "a small world where all kinds of smart devices are continuously working to make inhabitants' lives more comfortable".

To operate effectively, smart environments rely on four key properties: context awareness (the ability to understand the surrounding environment), automation, adaptation, and remote access. Because users physically live and operate inside these systems, the stakes are significantly higher than in traditional IT systems. If a standard social media platform is compromised, the result is restricted access to content and user frustration. However, in a smart environment, security failures immediately translate to physical consequences, meaning privacy failures become deeply personal, and security breaches threaten human safety. For instance, a compromised nuclear power plant could cause catastrophic damage to surrounding cities and citizens.

Smart environments have permeated almost every sector of modern life:

- **Smart Homes:** Featuring voice assistants, connected cameras, smart locks, thermostats, and modern appliances.

- **Smart Buildings:** Managing HVAC systems, lighting, access control, and elevators via protocols like BMS, BACnet, and KNX.
- **Smart Cities and Mobility:** Coordinating traffic lights, public transport, and connected autonomous vehicles.
- **Smart Grids and Utilities:** Utilizing smart meters, substations, and water treatment facilities.
- **Smart Healthcare:** Integrating wearables, implantable devices, and fully connected hospitals.
- **Smart Industry (Industry 4.0):** Utilizing Programmable Logic Controllers (PLCs), robotics, and digital twins.
- **Immersive and Mobile Spaces:** Expanding into XR headsets and drone technologies.

## The Common Operational Pattern

Regardless of the application domain, a smart environment operates on a continuous, four-step common path:

1. **Sense:** Sensors collect continuous data about people and the physical world. In some cases, data collection is constant, while in others, it is triggered by specific conditions.
2. **Connect:** Data is transmitted through heterogeneous wireless and wired links, utilizing gateways and cloud back-ends to provide information both inside and outside the smart environment.
3. **Analyze (Learn):** The system applies rules, analytics, and increasingly, Machine Learning (ML) either at the edge or within the cloud to understand the collected data.
4. **Act:** Actuators change the physical state of the environment (e.g., opening a window, heating a room, moving a robotic arm, or turning off the AC) based on the analyzed data.

This continuous cycle deals with data that is deeply personal; everything sensed can be related to confidential information.

## 1.2 The Internet of Things (IoT) Ecosystem

The foundational building blocks of every smart environment are IoT devices—the "things" comprising the Internet of Things. The European Network and Information Security Agency (ENISA) defines the IoT as a "cyber-physical ecosystem of interconnected sensors and actuators which enable intelligent decision

making". The ITU-T expands on this, describing it as a global infrastructure for the information society that enables advanced services by interconnecting physical and virtual things based on interoperable communication technologies.

A "thing" within the IoT can be practically any object in the physical or information world capable of being identified and integrated into a communication network. While some "things" are unconstrained devices like smartphones or servers, the vast majority are embedded systems. These IoT devices are typically constrained, meaning they are designed for specific, limited operations and possess restricted energy and computational power.

An embedded IoT device is essentially a small computer featuring a processing unit (CPU/microcontroller), non-volatile memory, a power supply (battery or direct cabling), and connectivity modules (wired or wireless).

## Sensors and Actuators

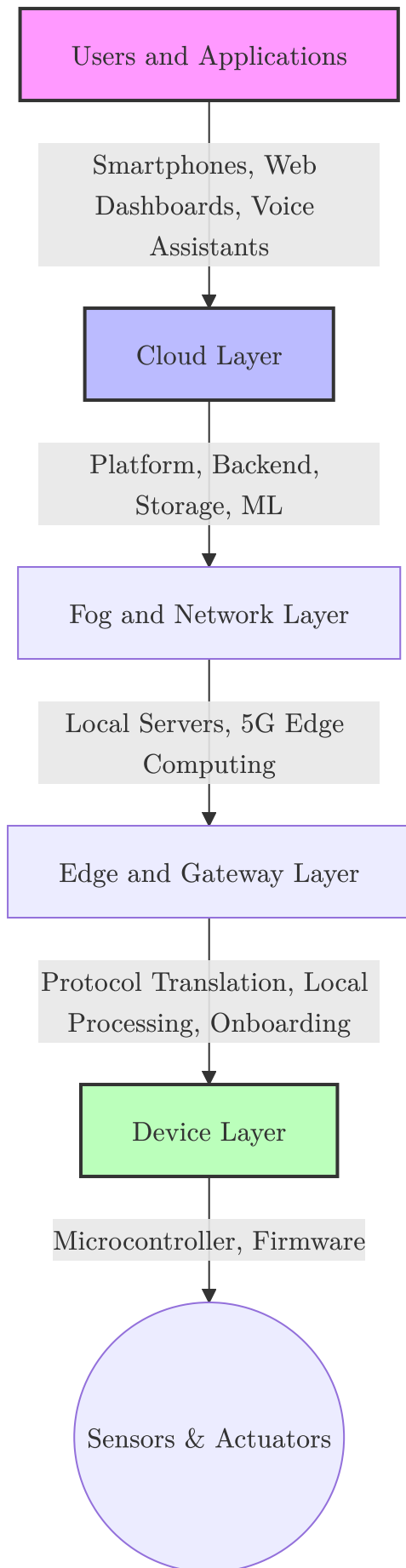
Sensors and actuators are the critical hardware interfaces between the digital and physical realms.

- **Sensors:** These elements monitor the environment and context in which the IoT system operates. They collect information from the digital space and can measure specific physical, chemical, or biological indicators, as well as digital network and application metrics. Examples of biometric monitoring sensors include body position sensors, temperature sensors, sound generators, ECG sensors, EMG sensors, airflow sensors, snore sensors, spirometers, glucometers, SP02 pulse oximeters, and blood pressure sensors.
- **Actuators:** These entities operate in the reverse direction of a sensor. They are responsible for producing a change in the physical world by moving or controlling a system mechanism in response to a digital command. They take an electrical input and transform it into a physical action, such as opening a window.

A classic example of intelligent decision-making combining these elements is automated diabetes management, where a continuous glucose sensor feeds data to a control algorithm, which in turn commands an actuator (an insulin pump) to physically deliver the correct dosage to the patient.

## 1.3 Layered Architecture and Ecosystem Complexity

IoT environments rely on a heavily structured, layered architecture to manage the flow of data from physical collection to cloud processing. Because users often want to control smart environments from outside the local network (e.g., managing a smart home from a remote office), devices must communicate externally via gateways that send information to the cloud.



The standard IoT architecture consists of the following layers:

1. **Device Layer:** Contains the physical sensors, actuators, microcontrollers, and firmware. This layer is physically exposed and resource-constrained.
2. **Edge and Gateway Layer:** Responsible for collecting data, protocol translation, local processing, and device onboarding. It makes data available to the internet and notably sees traffic in cleartext when it re-encrypts data.
3. **Fog and Network Layer:** Houses local servers and 5G edge computing, serving as a layer where data can be immediately processed for latency-critical analytics.
4. **Cloud Layer:** Acts as the richest target for attackers, housing the platform, back-end infrastructure, data storage, machine learning modules for deep analysis, and third-party services.
5. **Users and Applications:** Includes smartphones, web dashboards, and voice assistants used to control and manage the environment.

Crucially, every single boundary between these layers acts simultaneously as a potential point of attack and a necessary place to implement defense mechanisms (such as authentication, encryption, and monitoring).

## Scale, Protocols, and Assets

The sheer scale of IoT deployment exacerbates security concerns. The number of IoT connected devices has already surpassed the number of humans on the planet. While early predictions by Cisco in 2011 forecasted 50 billion connected devices by 2020 (a number that fell short to about a quarter of that in reality), current data from IoT Analytics shows explosive growth. There were 18.5 billion connected IoT devices at the end of 2024, with a forecast of 21.1 billion by the end of 2025, 39 billion expected by 2030, and a projection to surpass 50 billion by 2035. Each of these billions of cheap, long-lived devices represents a potential entry point for malicious actors, and unfortunately, most will never receive a security patch.

Because IoT devices are highly heterogeneous and possess differing energy and operational constraints, the ecosystem relies on a fragmented landscape of communication protocols spanning PAN (Personal Area Network), LAN (Local Area Network), MAN (Metropolitan Area Network), and WAN (Wide Area Network). These include Wi-Fi, Bluetooth (BLE), UWB, Z-Wave, Zigbee, 6LoWPAN, NFC, RFID, and cellular technologies (4G/LTE/5G/NB-IoT).

Consequently, the assets comprising an IoT ecosystem are vast and diverse. They range from the physical hardware (microprocessors, physical ports, power supplies) and software (operating systems, firmware running the devices) to network

infrastructure (routers, gateways, firewalls, IPS/IDS) and the massive troves of information stored at rest, in transit, and in use.

## **Chapter 2: IoT Threats, Vulnerabilities, and the Evolution of Security**

### **2.1 The Inherent Security Flaws of IoT**

In the technology sector, there is a running joke depicted in industry circles: "Did you know the 'S' in IoT stands for Security? But... there is no 'S' in IoT". The fundamental problem with IoT security lies deeply within its initial design architecture. Originally, these devices and their underlying protocols were crafted strictly for private, isolated communication networks. As they were eventually moved to standard IP networks and later exposed to the public Internet, security was largely treated as an afterthought.

Early security measures were extremely basic, relying heavily on simple authentication and embedded (hardcoded) passwords, making it incredibly easy for bad actors to find and exploit security faults. More complex security requirements were only attached to the technology later in its lifecycle. Consequently, legacy devices designed with low security standards are still widely deployed globally, often forced to operate in compatible fall-back modes that negate modern protections. Furthermore, applying firmware updates to these constrained devices is notoriously hard—or nearly impossible—after they have been physically installed in the field.

In cybersecurity, a system is broadly recognized as being only as secure as the weakest link composing its chain. Traditionally, this weakest link is considered to be the human user. However, in smart environments, the ecosystem is flooded with cheap devices that completely fail to implement basic security solutions, introducing massive new attack surfaces. Strikingly, the weakest link of a smart environment is often not even the physical device itself, but rather its ecosystem interfaces (such as cloud APIs, backend services, or dealer web portals).

### **2.2 Real-World Consequences: What Could Possibly Go Wrong?**

Security failures in smart environments are not just digital data breaches; they translate directly into physical safety threats and deeply personal privacy

violations. Over the years, numerous high-profile vulnerabilities have demonstrated the severe stakes involved:

- **Automotive and Physical Security:** Hackers have successfully intercepted signals to bypass Bluetooth smart locks, and famously demonstrated the ability to remotely take over and kill a Jeep Cherokee's engine while it was driving on the highway. Vulnerabilities in third-party analysis apps have also allowed unauthorized remote access to modern vehicles like the Tesla Model S.
- **Medical Devices:** Research has highlighted critical security flaws in connected medical devices, such as pacemakers and insulin pumps, raising legitimate fears that hackers could exploit these vulnerabilities to demand ransom or cause direct physical harm to patients.
- **Privacy Violations:** Connected toys, such as "My Friend Cayla" dolls and intelligent robots, have violated fundamental privacy protections by actively recording children's conversations without parental consent.

## Recent Incidents (2020 - Present)

Despite growing industry awareness, the root causes of IoT attacks—default credentials, unnecessary network exposure, lack of updates, and vulnerable ecosystem interfaces—have remained tragically unchanged since the previous decade.

- **Verkada (2021):** Approximately 150,000 security cameras located in highly sensitive areas like hospitals, prisons, and factories were exposed to attackers via a leaked super-admin credential.
- **CyberAv3ngers (2023):** Unitronics PLCs utilized in US water utilities were hijacked through the simple exploitation of default passwords.
- **Kia (2024):** Researchers discovered they could remotely control millions of Kia cars (allowing them to locate, unlock, start, and honk the vehicles) in under 30 seconds simply by inputting a license plate number into a vulnerable dealer web portal API.
- **BadBox 2.0 (2025):** Emphasizing supply-chain risks, about 10 million Android TV boxes and projectors shipped directly from the factory pre-infected with a backdoor used for ad fraud and proxying.
- **Aisuru and Kimwolf (2025-2026):** These Mirai-descendant botnets set massive Distributed Denial-of-Service (DDoS) attack records exceeding 30 Tbps, proving that while target devices change, the underlying lack of ecosystem hardening remains heavily exploitable.

## **2.3 The Three Ages of IoT Security**

The historical trajectory of IoT threats and corresponding defensive postures can be systematically divided into three distinct eras:

### **1. The Age of Exploration (2005 - 2009)**

During this initial period, security was simply not a priority for IoT and embedded devices. Organizations assumed that no one would bother attacking these devices, especially since they were running in isolated or air-gapped networks. Most cyberattacks at the time were limited to standard malware and viruses impacting Windows-based embedded control systems. Defensive methods relied heavily on "security by obscurity" (e.g., hiding the OS or application details)—a practice that fundamentally never works. Minimal security controls were easily bypassed, and secure protocols (like SSH or SSL) were rarely implemented beyond a few niche systems.

### **2. The Age of Exploitation (2011 - 2019)**

As the sheer number of connected devices exploded and cloud connectivity became commonplace, attackers recognized the opportunity and actively began targeting IoT devices. Criminals improved their ability to monetize these attacks through crypto-mining, ad-click fraud, spam email campaigns, and massive botnets like Mirai. Additionally, nation-state actors began leveraging IoT devices to conduct politically motivated infrastructure attacks. In response, new security technologies began to be adopted (such as TLS/SSH protocols, Secure Boot, TPM/Secure Elements for secure key storage, hardened operating systems, and embedded firewalls). However, their use was often inconsistent, incomplete, and sometimes flawed, leaving a vast ecosystem of devices still highly vulnerable to exploitation.

### **3. The Age of Protection (2020 - Present)**

Today, connected devices are ubiquitous in every area of life. In response to the growing severity and volume of attacks, companies now fully acknowledge that their devices can be vulnerable and actively work to introduce robust security aspects from the ground up. Governments and industrial groups have begun enacting legislation that legally requires higher levels of security for IoT devices. Recognizing that hackers will continually search for "soft targets" in legacy devices lacking strong defenses, organizations worldwide are adopting unified solutions and security frameworks, implementing key technologies that work together to provide multiple, overlapping layers of protection.

